9. Trust boundaries

Boundary	Control that holds	What is on the public side
Browser to Nutshell	Vercel HTTPS.	The /api/board route writes Atlas from the document in the body. It does not check the bearer the ticket API uses.
Nutshell to board API	Forwards the caller bearer and the first X-Forwarded-For value. Password is not stored in the app.	503 when BOARD_API_URL is empty or the directory cannot be reached.
Caller to in-process MCP	Bearer required on tools/call. Scopes and org rules run in the store.	Install URL is the public Nutshell /mcp path.
Caller to Python MCP	Bearer required. Same token is forwarded. Inbound 8080 is limited to the load balancer after apply.	ALB certificate is self-signed. Origin protection is off. The documented client URL stays the Vercel path.
Board API to LLDAP	User bind for login. Admin bind for create. Sockets are closed after the bind.	TCP 3890 and the admin UI on 17170 allow the internet. LDAP is not LDAPS. Task disk loss drops users created at the event.
Board API to Redis	Password on the server. Rate limits and pub/sub only.	TCP 6379 is public and has no TLS. Data is memory only.
Board API to Atlas	TLS. URI in SSM. Writes happen only after the store accepts the actor.	Atlas network access allows public IPv4. auth_tokens retains bearer secrets so restarts can authenticate.
UI to Atlas	Connection string on the Vercel project. Collection names match shared/names.	The board route is a direct document upsert, separate from token policy.
Caller to buck-track	Actor object required on mutations. Versions are write-once. SSH closed. IMDSv2. Encrypted volumes.	TCP 8787 is public. There is no bearer check.
Browser to upload buckets	Presign only. Quarantine and clean block public access. Bucket policy denies non-TLS.	The callback token is the scanner's credential to the app. The worker is stopped when the callback URL is empty.
Operator to AWS	SSM for the VPS. Execution role reads /buc2agent/* parameters. Task role may assume the upload app role.	Terraform state on the operator machine contains generated secrets. ECR tags are mutable. Scan on push is off. Logs are kept 7 days.

Identity boundary, in one line

LLDAP holds human passwords. Atlas holds people, agents, and bearers. The token is the actor. An agent cannot outgrow its owner, cannot approve, and cannot close until a different human has approved.